SIEM Post-Implementation Report

Jonathon S. Lutes

SIEM Post-Implementation Report

A. Adopted Policies 2

Cybersecurity Decision Making 4

B. Assurance Criteria 5

Automation 5

Modernization 6

Industry-standard tools and infrastructure 6

C. Data Collection and CIA Principles 7

D. Investigation and Mitigation 8

E. Plans, Standards, or Procedures 9

Regulatory Compliance 9

Tools and Guides 10

F. Post-Implementation Environment 10

Efficiency of Solution 11

Analysis of New Data 12

Summative Evaluation Plan 12

Post-Implementation Risks 14

Meeting Stakeholder Needs 15

G. Post-Implementation Maintenance Plan 17

H. Project Artifact 18

I. References 19

A. Adopted Policies

FinTek is a financial technology company, and because of its size and the vertical it operates in, it is a target for various threat actors, ranging from unskilled individuals to nation-state-funded groups. The organization has relied on various network and security tools, many endpoints, and a cloud infrastructure that are all disconnected from one another. These factors, along with a Payment Card Industry Data Security Standard (PCI DSS) audit, prompted FinTek to evaluate options to improve its security systems and log collection. Before the project's implementation, the organization relied on 8 disconnected tools, which slowed decision-making. The newly implemented SIEM solution now enables faster, evidence-based triage decisions rather than guesswork across disconnected tools. Data can now be correlated across different tools, enabling more thorough, in-depth analysis of incidents. A pre-assessment audit was performed by an internal compliance analyst, who flagged 4 findings mapped to PCI DSS v4.0.1 Requirement 10 (PCI SSC, 2024). PCI DSS requirements, along with industry-wide best practices, necessitated the creation of the following policies during project implementation.

The first finding was that log review was performed ad hoc rather than on a scheduled basis as expected under Requirement 10.4. The implemented policy to address this finding is a centralized, scheduled review of logs. The policy, which exceeds PCI DSS Requirement 10.4.1, requires that all logs be reviewed daily via the SIEM, not just those related to the CDE system. The policy was chosen to exceed the minimum requirement because automation has made daily review low-cost.

Finding 2 stated that log retention periods were inconsistent across the various tools, ranging from 30 days to 13 months, creating a risk of gaps in the 12-month history PCI DSS expects to be readily available. To meet Requirement 10.5.1, the newly implemented log retention policy requires that the last 3 months be immediately searchable and that logs from the last 4 to 12 months be archived.

The next finding was that there was no file integrity monitoring or centralized mechanism to detect tampering with audit logs, indicating a compliance gap under Requirement 10.3. To meet this requirement, a log integrity and tamper-evidence policy has been implemented. All log data ingested into the SIEM is stored in indexed, write-protected storage and verified through cryptographic hashing. This ensures that log entries cannot be deleted or altered without detection once the SIEM has received the data. Access to the log store is logged and restricted to the Lead Security Architect and the Security Operations Center (SOC) Operations Manager. Any detected mismatch or unauthorized modification attempt triggers an immediate alert and is treated as a security incident.

The final finding was that there was no automated alerting for anomalous access to Cardholder Data Environment (CDE) systems. FinTek has adopted an automated CDE access-alerting policy that requires real-time alerts for all access attempts to systems within the CDE, replacing the manual review process the organization previously relied on. The policy mandates that correlation rules within the SIEM continuously monitor authentication and access activity to the CDE network segment, flagging attempts that fall outside expected patterns, for immediate SOC review.

Another policy that was implemented through the project is role-based SIEM access. The policy focuses on the principle of least privilege, ensuring all users, programs, and systems are restricted to the minimum permissions and data needed to perform their roles. Access to the SIEM is controlled by a role-based access policy, ensuring that each user's visibility into the platform is limited to what their role requires. This policy aligns with the access control practice outlined in the SANS Log Management Policy and reinforces the log integrity protections already in place.

Cybersecurity Decision Making

The implemented SIEM solution has significantly improved cybersecurity decision-making in several key ways. Before the SIEM solution was implemented, SOC analysts would make triage and investigation decisions using fragmented, uncorrelated data spread across eight disconnected tools. This process consumed an estimated 5 hours per analyst per day and was the largest factor in a mean time to detect of 9.5 hours and a mean time to respond of 17 hours. Each tool operated in isolation, and analysts frequently were forced to make escalation decisions with partial visibility, manually reconciling different log formats and timestamps before they could begin assessing whether an event represented a genuine threat.

The solution fundamentally changed this process by presenting analysts with correlated, normalized data from all eight sources on a single platform. Rather than having to manually piece together activity from firewalls, endpoints, identity systems, and cloud logs to determine whether an event is part of a broader pattern, analysts now receive alerts enriched with cross-source context. This shifts decision-making from reactive, where analysts had to decide if an investigation was worth the time required to gather supporting evidence, to evidence-based triage, where the supporting evidence is already assembled when a decision needs to be made.

This improvement extends beyond the micro level of individual alert triage to the macro level of FinTek's broader security posture. Correlation rules aligned with the MITRE ATT&CK framework (*MITRE ATT&CK® n.d.*) enable the SOC to make risk-based prioritization decisions based on recognized adversary behavior, rather than treating all alerts as equally urgent. The centralized log store also provides the Compliance and Data Privacy Officer and the Lead Security Architect with a reliable single source of evidence for a post-incident review or decision-making during a compliance audit. In both cases, the SIEM has replaced decisions previously made with incomplete information with decisions supported by correlated, verifiable data.

B. Assurance Criteria

The technology solution implemented for FinTek accomplishes automation, modernization, and the use of industry-standard tools and infrastructure.

Automation

Before the SIEM project implementation, FinTek's SOC analysts had to manually triage and investigate security events across various disconnected tools, a process that consumed approximately 5 hours per analyst per day. The SIEM solution replaces this manual process with automated correlation rules that analyze incoming log data and generate enriched alerts, eliminating the need for analysts to cross-reference sources first. Automated alerting for CDE access further reflects this shift by replacing the manual review process with continuous, rule-based monitoring. This also directly satisfies PCI DSS Requirement 10.4.1, which mandates the use of automated log review mechanisms.

Modernization

The solution also replaces FinTek's previous environment of eight independently managed tools with a single, centralized SIEM platform, eliminating the fragmented retention practices and inconsistent schemas that characterized the organization's prior logging methodology. Hosting the platform in the cloud further modernizes FinTek's infrastructure by offloading hosting and maintenance to external providers, allowing the Lead Security Architect and IT Operations team to focus on detection engineering and log source integration rather than infrastructure upkeep.

Industry-standard tools and infrastructure

The solution is built on Splunk Cloud, a widely adopted enterprise SIEM platform, and its correlation rules are explicitly mapped to the MITRE ATT&CK framework, ensuring detections are grounded in recognized adversary tactics and techniques rather than being developed ad

hoc. The implemented solutions design has been further guided by the NIST Cybersecurity Framework 2.0 Detect function and the SANS Log Management Policy, both industry frameworks that informed decisions ranging from log source prioritization to role-based access control (*National Institute of Standards and Technology* 2024). Together, these standards ensure the solution reflects recognized industry practice.

C. Data Collection and CIA Principles

Before implementation, FinTek was limited in its ability to conduct forensic analysis following a security incident due to the fragmented nature of its logging environment; evidence was scattered across eight disconnected tools, each using different formats. Data collection is now accomplished as part of this project through the SIEM solution. The SIEM solution serves as a centralized repository for digital evidence, ingesting and normalizing log data from all sources into a single, correlated timeline. The centralized nature of the SIEM allows investigators to reconstruct the sequence of events surrounding an incident without manually aligning timestamps and formats across separate consoles. Combining this with the retention log policy gives FinTek the tools necessary to support internal and external investigations.

Confidentiality is enforced through the principle of least privilege; the role-based SIEM access policy limits each user's visibility to what their role requires. SOC Analysts can view investigation-focused dashboards and alerts. At the same time, administrative access is restricted to the Lead Security Architect and SOC Operations Manager, ensuring sensitive data, including authentication records and Cardholder Data Environment activity, is not exposed to users without actual operational need.

Integrity is addressed through the log integrity and tamper-evidence policy. All log data ingested into the SIEM is stored in write-protected, indexed storage and verified through cryptographic hashing, ensuring that once a log entry is received, it cannot be altered or deleted

without detection. This gives the organization confidence that the evidence used for both incident investigations and compliance reporting accurately reflects what actually occurred.

Availability is supported by adopting Splunk Cloud, which shifts infrastructure hosting and uptime management to a managed service, reducing reliance on internally maintained hardware. This reduces the risk of the logging and monitoring platform itself becoming a single point of failure during an active security incident, ensuring that correlated log data and alerting remain accessible to the SOC precisely when they are most needed.

D. Investigation and Mitigation

The implemented SIEM solution enables FinTek to investigate and mitigate security incidents within its environment much more easily than before. Correlation rules built during implementation allow analysts to trace multi-stage attacks across previously disconnected systems. In the organization's previous system, when investigating this type of attack, an analyst would need to access the logs of each tool manually, which they believed was relevant to their investigation, and collect the necessary logs. Gathering those logs would become the bottleneck of the investigation, as it was extremely time-consuming. Using the implemented SIEM solution, analysts can now see logs automatically correlated, enriched, and timestamped, enabling complex investigations that take significantly less time.

The SIEM solution also strengthens FinTek's ability to mitigate incidents once they have been identified. Automated alerting on anomalous CDE access allows the SOC to intervene during an active intrusion attempt rather than discovering it after the fact during a delayed, manual log review. The incident response runbook, developed alongside the SIEM, provides analysts with a structured escalation path once an alert is confirmed, ensuring that containment actions are performed consistently rather than relying on an individual analyst's judgment under time pressure. Together, faster detection and a defined response process reduce the window in

which an attacker can operate undetected within FinTek's environment, directly addressing the risk of prolonged, unnoticed compromise identified throughout this project.

E. Plans, Standards, or Procedures

To implement SIEM for FinTek, it was necessary to develop a set of formal plans, standards, and procedures governing how the organization logs, monitors, and responds to security events. These were shaped by the policies established to mitigate the audit findings and by the regulatory requirements driving this project. These plans, standards, and procedures ensure that day-to-day operational practices align with both PCI DSS obligations and the industry frameworks that guide solution design.

Regulatory Compliance

Regulatory compliance is a vital aspect of FinTek's business model, as it allows it to avoid fees and penalties imposed by its acquiring bank. The plans, standards, and procedures developed during project implementation align with PCI DSS v4.0.1 Requirement 10, Logging and Monitoring, as well as the broader industry frameworks that guided the solution's design. The scheduled log review satisfies Requirement 10.4, which mandates regular review of security events and logs from systems that store, process, or transmit cardholder data. The automated CDE access-alerting policy satisfies Requirement 10.4.1.1, which requires automated log review mechanisms (PCI SSC, 2024). Requirement 10.3 requires that audit trails be secured against alteration, and the log integrity and tamper-evidence policy fulfills that requirement. Lastly, the log retention policy satisfies Requirement 10.5.1, which requires at least 12 months of audit log history with the most recent 3 months immediately available for analysis.

Beyond PCI DSS, these plans reflect the industry frameworks. The NIST Cybersecurity Framework 2.0 Detect function informs which systems and activities are continuously monitored and how correlated data is analyzed to characterize security events. At the same time, the

SANS Log Management Policy's emphasis on centralized collection, automated detection, retention, and access control is directly reflected in the policies implemented during this project (SANS *Log Management Policy* 2026). Taken together, FinTek's post-implementation plans satisfy both the specific regulatory obligations driving this project and the broader industry best practices the solution was designed around, rather than treating compliance and sound security practice as separate concerns.

Tools and Guides

Several tools and reference documents were produced during implementation to support the plans, standards, and procedures described above, giving staff reusable resources rather than relying solely on institutional knowledge. The centralized Splunk Cloud platform is the primary tool underlying every policy in this section, serving as the mechanism for CDE access alerting, log review, retention, and integrity verification.

Supporting this platform are a set of configuration guides, organized by forwarding method, syslog-based, agent-based, and API-based, that give IT staff fixed, step-by-step instructions for connecting each of FinTek's log sources to the SIEM. These guides remain available as a reference for onboarding any future systems added to the environment. The incident response runbook provides SOC analysts with a structured, branching reference for triaging and escalating alerts generated by the SIEM's correlation rules, translating the automated alerting policies described in Section A into consistent analyst actions. Finally, the PCI DSS compliance reporting template consolidates evidence from the centralized SIEM into a format aligned with Requirement 10, giving the Compliance and Data Privacy Officer and external auditors a repeatable way to demonstrate logging and monitoring.

F. Post-Implementation Environment

With the SIEM fully deployed, FinTek's security environment is now substantially different from the disconnected and fragmented state it was in at the outset of this project. The organization's eight previously disconnected tools, Qualys, CrowdStrike Falcon, Veeam, Proofpoint, Palo Alto NGFW, Azure Monitor, Windows Server/Active Directory, and Imperva, now feed normalized and correlated into the Splunk Cloud instance, automating alerting and providing centralized dashboards. Governing how the SOC interacts with log data are the new processes introduced during implementation, including scheduled log review, log retention, log integrity, and CDE access-alerting policies.

The following sections will evaluate this new environment in detail: the efficiency gains, the new data available to the organization, the results of the summative evaluation plan, the risks that remain or have emerged now that the system is live, and the extent to which the solution has met the needs of each relevant stakeholder.

Efficiency of Solution

The implemented SIEM solution significantly improved FinTek's security posture and SOC efficiency. The solution strengthens the security posture by resolving the three root causes identified during the project's initial assessment: FinTek now has a centralized log aggregation and correlation platform, cross-tool alerting capable of detecting multi-stage attacks, a standardized logging schema, and automated processes. Each of the four findings from FinTek's internal PCI DSS gap assessment has likewise been remediated through the implemented policies, closing the identified compliance gaps.

The solution eliminates most of the manual log-gathering work that previously consumed SOC analysts' time, thereby dramatically increasing SOC efficiency. Before implementation, of the 12-minute average investigation time, roughly 7 minutes, or 58 percent, was spent manually

correlating logs across various disconnected tools, taking time away from actually investigating. That time is largely eliminated, as the SIEM gathers and correlates data, reducing the total analyst time spent on daily alert handling from an average of 5 hours per analyst to roughly 2 hours, freeing the remaining time for proactive threat hunting, rule tuning, and other higher-value work. This improvement is similarly reflected in detection and response speed: mean time to detect (MTTD) fell from FinTek's 9.5-hour baseline to an average of 1.5 hours, and mean time to respond (MTTR) fell from 17 hours to approximately 4 hours.

Analysis of New Data

The implemented solution allows FinTek to track several new categories of data. Correlated and normalized logs from all eight log sources are available within a single unified platform. This allows analysts to query activity across the network, endpoint, identity, and cloud layers simultaneously, without having to retrieve each source separately. Correlation rule alert reports provide a running record of flagged activity mapped to MITRE ATT&CK techniques, giving the SOC total visibility into which attack patterns are detected and how frequently they occur. Role-based dashboards generate real-time summaries of network, infrastructure, and endpoint activity.

The new data FinTek now collects directly affects FinTek’s existing business processes. The SOC’s daily workflow shifts from manually checking eight separate consoles to reviewing a single centralized dashboard. This allows the scheduled log review to shift from a time-consuming, fragmented task to a streamlined daily check. The Compliance and Data Privacy Officer’s audit preparation process is also affected, since evidence that previously had to be manually assembled from various sources can now be pulled directly from the SIEM using a compliance reporting template. Decision-making throughout the organization, from SOC Analysts triaging to the Lead Security Architect evaluating the platform’s overall performance, now draws on a consistent, correlated data source rather than the fragmented, source-specific

reporting that characterized FinTek's previous environment. This dramatically reduces the likelihood that decisions are made on incomplete information.

Summative Evaluation Plan

Summative testing was conducted at the conclusion of Phase 5 of the project, before the project's complete implementation. The testing evaluated the SIEM as a complete system, not just its individual components. This testing included full end-to-end validation against four test scenarios developed during implementation. The tests were: a simulated credential compromise with lateral movement toward the CDE; a simulated unauthorized access attempt against the CDE; a simulated log tampering attempt; and a simulated multi-source incident that required correlation across the firewall, Endpoint Detection and Response (EDR), and Active Directory logs. These tests were then evaluated against the acceptance criteria, including ensuring that all eight priority log sources successfully ingest and normalize data before go-live, and that at least ten correlation rules are developed and validated against MITRE ATT&CK techniques. The SIEM must demonstrate a measurable reduction in MTTD and MTTR relative to FinTek's current baseline, and a false-positive rate of under 5%.

Results of the tests measured against these criteria were largely successful on the first pass. All eight log sources were confirmed to ingest and normalize data correctly, and the correlation rule library included 12 rules mapped to MITRE ATT&CK techniques. Each of the four test scenarios was detected successfully, with correlation rules correctly flagging the simulated activity and dashboards accurately reflecting the scope of each incident. One criterion was not met on the first pass of testing: the false-positive rate in the multi-source correlation scenario reached 12%, exceeding the established 5% ceiling, with several rules flagging legitimate activity as suspicious. In response, the correlation rules were returned to Phase 4 for additional tuning, following the process outlined in the project proposal. The Lead Security Architect adjusted correlation thresholds and added suppression logic for known-benign

administrative patterns, after which the affected scenarios were retested. The second round of summative testing confirmed that the false positive rate had fallen below the 5% ceiling without reducing any rules' ability to detect the original test scenarios, after which the project was considered to go live.

Post-Implementation Risks

Several risks remain in FinTek's environment post-SIEM implementation. Although these risks are now different from those pre-implementation, they still pose ongoing operational exposure.

As attacker techniques evolve and FinTek's environment changes, correlation rules built during Phase 4 of the project gradually lose effectiveness, leading to correlation rule staleness and posing a medium-likelihood, medium-impact risk. This risk is mitigated by a recurring rule-review cadence, which ensures the use-case library remains up to date.

Key-person dependency is a medium-likelihood, high-impact risk post-implementation because the Lead Security Architect has the deepest technical knowledge of the SIEM's correlation rule architecture and configuration. The organization would face significant difficulty in maintaining the platform if the Lead Security Architect were to leave unexpectedly. This risk is mitigated by extending the Splunk Core Certified Power User training to the SOC Operations Manager as a secondary resource. The configuration guides and the use-case library documentation also need to be detailed enough to support a transition if needed.

When moving any resources to a cloud vendor, an inherent risk is cloud vendor dependency. This risk has a low likelihood and high impact on the organization. FinTek's logging and monitoring capability now resides in Splunk Cloud rather than on-premises. If Splunk were to have an extended outage or service disruption, it would directly affect FinTek's ability to detect and respond to security incidents. This risk is mitigated through Splunk Cloud's managed

uptime commitments. FinTek should also periodically reassess whether a contingency plan is necessary for extended outage scenarios.

Meeting Stakeholder Needs

Chief Information Security Officer (CISO)

CISO involvement was critical for this project, as they own FinTek's overall security strategy and approve the SIEM implementation. A major need for the CISO was assurance that the project's implementation would reduce the organization's risk, satisfy audit obligations, and do all this within the allotted budget. The implemented SIEM resolved all three root causes and all four of the PCI DSS-identified findings. The final cost for the first year of the SIEM solution is approximately $59,840 and remains within the budget range. These provide the CISO with the risk reduction and audit readiness required to meet their needs.

Chief Financial Officer (CFO)

The CFO was the budget and business authority for the project; as such, they had the final sign-off on whether the project got funded. The CFO approved and funded the project, and they needed a clear cost-benefit case to justify the investment to leadership. The completed project delivers a year-one cost of $59,840, compared with the previously estimated $230,000 in lost time from manual investigation. This provides the CFO with a documented return that applies to all subsequent years, at a lower annual licensing cost of $43,800.

SOC Operations Manager

The SOC operations manager oversees the SOC's day-to-day operations, manages the team through the SIEM transition, and implements the new monitoring workflow. They needed the SIEM to fit into existing shift structures and staffing. Daily alert handling time has been reduced to an average of 2 hours per analyst, dropping from the previous 5 hours. The

completed solution directly reduces the overtime and missed-alert pressure the SOC Operations Manager was accountable for before implementation.

SOC Analysts

The SOC analysts are the end users of the SIEM and need an intuitive interface, reliable correlation rules, and reduced manual log collection for the project to succeed. The correlated, enriched alerts now produced by the SIEM eliminate the majority of the log-gathering work that analysts had to perform manually.

Lead Security Architect

The lead security architect was responsible for designing the technical integration of the SIEM into FinTek's existing network segments and needed accurate infrastructure documentation and cooperation on change control. The completed SIEM provides this through its centralized dashboards and network and data-flow diagrams, giving the Lead Security Architect visibility that their role previously lacked.

Data Privacy Officer (DPO)

The DPO needed assurance that the SIEM design and log retention practices complied with PCI DSS and data privacy obligations. They required visibility into what data is collected and how long it is retained. The CDE access-alerting, log retention, and integrity policies satisfy this need, and the DPO's sign-off during Phase 6 confirmed these requirements were met.

IT Operations/Network Team

The IT operations and network team were responsible for configuring log forwarding from endpoints, servers, and switches during SIEM onboarding. They needed a clear list of log sources and a rollout schedule that avoided disrupting production systems. During

implementation, configuration guides were produced to provide the IT Operations/Network team with the structured reference needed to complete onboarding in Phase 3 without disrupting FinTek's systems.

PCI DSS Qualified Security Assessor

The PCI DSS Qualified Security Assessor (QSA) was not involved in the SIEM implementation. However, they need to review evidence that logging and monitoring controls meet the PCI DSS requirements during the upcoming audit. The PCI DSS compliance reporting template provides the QSA with a repeatable way to verify compliance with Requirement 10 during audits.

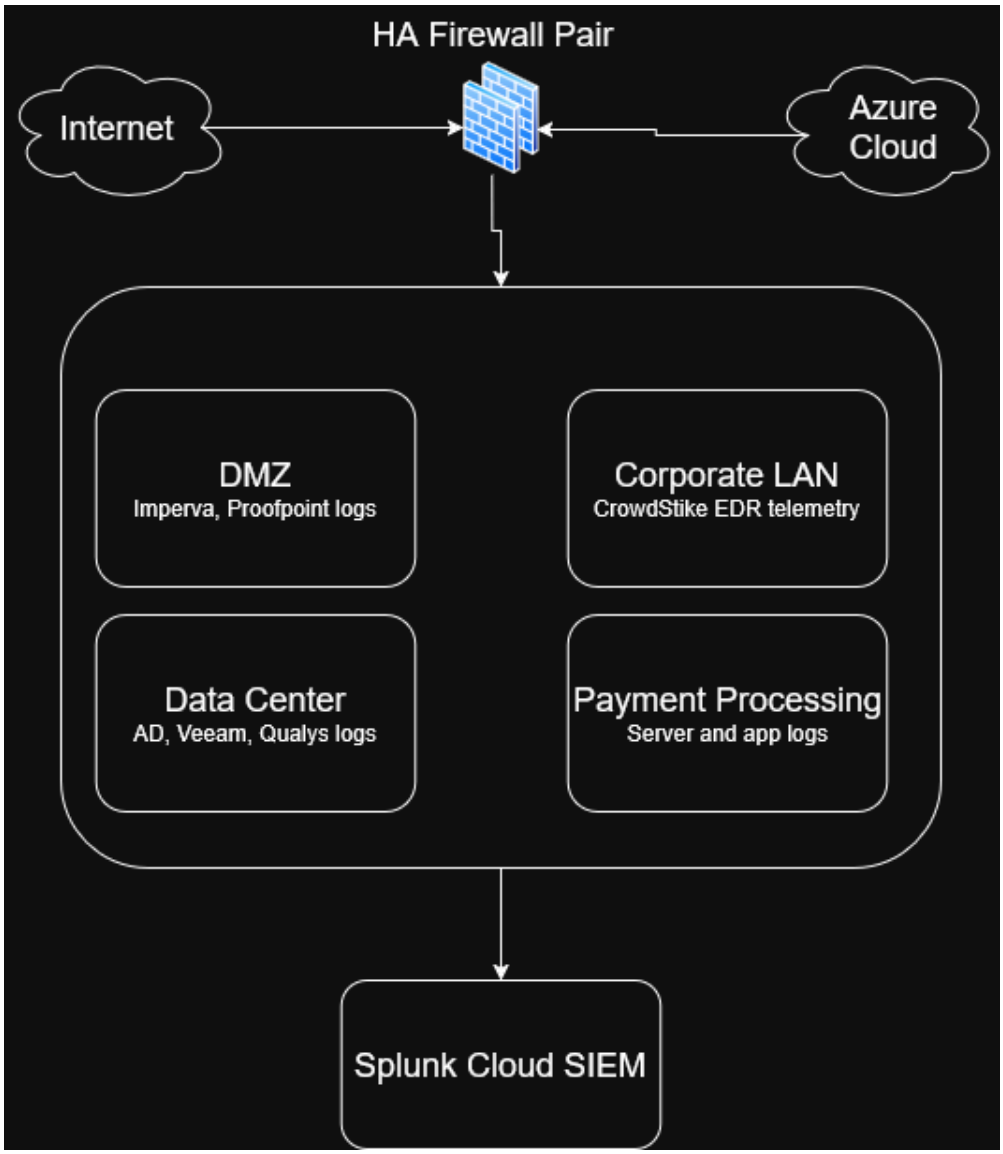
G. Post-Implementation Maintenance Plan

This plan addresses post-implementation risks and establishes ownership of maintenance activities going forward.

Correlation rules are to be reviewed quarterly to ensure that the use-case library remains aligned with MITRE ATT&CK techniques and FinTek's evolving environment. This review will include reassessing false positive rates and adjusting thresholds as needed, treating the tuning performed during the project as an ongoing task. Log source health should be monitored on an ongoing basis to confirm that all log sources are being ingested and normalized correctly by the SIEM, as a failure in any source ingestion would reintroduce visibility gaps the project was designed to eliminate. Certifications and required training are to be refreshed regularly to keep existing staff current with the platform's capabilities. Relevant certifications and training will also be provided to onboard new Lead Security Architect, SOC Operations Manager, or SOC Analyst roles. Lastly, a recurring PCI DSS audit-readiness review will be conducted ahead of each audit cycle. The compliance reporting template will be utilized to confirm that CDE alerting, log review,

and retention policies remain in effect and documented. Primary ownership of this plan rests with the Lead Security Architect, who oversees the technical aspects, with the SOC Operations Manager, who shares responsibility for training and day-to-day operational feedback to inform ongoing SIEM rule tuning.

H. Project Artifact



Network and Data-Flow Diagram

I. References

PCI Security Standards Council. (2024). Payment Card Industry Data Security Standard: Requirements and testing procedures (Version 4.0.1). https://www.pcisecuritystandards.org/

Mitre ATT&CK®. MITRE ATT&CK®. (n.d.). https://attack.mitre.org/

National Institute of Standards and Technology. (2024, February 26). National Institute of Standards and Technology. The NIST Cybersecurity Framework (CSF) 2.0. https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf

Log Management policy. SANS Institute. (2026, February). https://www.sans.org/information-security-policy/log-management-policy